Dossier de conformité RGPD — FileFlow

Titre	Dossier de conformité au Règlement Général sur la Protection des Données
Produit	FileFlow — plateforme de partage de fichiers auto-hébergée
Version	1.1
Date	27 octobre 2026
Statut	Validé
Propriétaire	Driss OUAAZIZ — Software Architect
Contributeurs	Driss OUAAZIZ — Software Architect
Classification	Interne

Table des matières

1. Objet
2. Rôles et responsabilités
3. Registre des activités de traitement (art. 30)
4. Protection des données dès la conception et par défaut (art. 25)
5. Droits des personnes concernées et modalités d'exercice
6. Évaluation du besoin d'analyse d'impact (art. 35)
7. Sécurité des traitements (art. 32)
8. Gestion des violations de données à caractère personnel
9. Références

1. Objet

Le présent dossier établit la conformité de FileFlow au Règlement (UE) 2016/679 (RGPD). Il précise la répartition des rôles, recense les traitements de données à caractère personnel mis en œuvre par le produit, décrit les mesures de protection des données dès la conception, expose les modalités d'exercice des droits des personnes, statue sur le besoin d'une analyse d'impact relative à la protection des données (AIPD), et renvoie aux mesures de sécurité et aux procédures de gestion des violations.

FileFlow étant un produit **auto-hébergé**, ce dossier distingue les obligations relevant de l'éditeur (fournisseur du logiciel) de celles incombant à l'organisation qui déploie et exploite le produit.

2. Rôles et responsabilités

ACTEUR	QUALIFICATION RGPD	RESPONSABILITÉS
Organisation déployant FileFlow	**Responsable de traitement**	Détermine les finalités et les moyens ; tient son registre ; recueille les bases légales ; répond aux demandes d'exercice des droits ; notifie les violations

ACTEUR	QUALIFICATION RGPD	RESPONSABILITÉS
Éditeur / équipe d'ingénierie FileFlow	**Fournisseur** (et, le cas échéant, sous-traitant technique)	Fournit un produit conçu selon les principes de protection des données dès la conception ; met à disposition les fonctionnalités permettant au responsable de tenir ses obligations
Exploitant / administrateur système	Personnel autorisé du responsable	Configure, sauvegarde et supervise l'instance ; applique les mesures de sécurité de l'hôte

Précision. En mode auto-hébergé, l'éditeur n'a aucun accès aux données traitées par une instance déployée. La responsabilité de traitement au sens de l'article 4.7 du RGPD incombe à l'organisation déployante. Le présent dossier fournit à cette dernière les éléments nécessaires à la tenue de ses propres obligations.

---

3. Registre des activités de traitement (art. 30)

Le tableau ci-dessous recense les traitements mis en œuvre par le produit. Il constitue un modèle que le responsable de traitement adapte à son contexte de déploiement.

TRAITEMENT	FINALITÉ	CATÉGORIES DE PERSONNES	CATÉGORIES DE DONNÉES	BASE LÉGALE (INDICATIVE)	DESTINATAIRES	DURÉE DE CONSERVATION
Gestion des comptes	Authentifier et autoriser les utilisateurs	Utilisateurs internes	Identifiant, empreinte de mot de passe, rôle, groupes, e-mail (optionnel), nom complet (optionnel), horodatages de création et de dernière connexion	Exécution d'un contrat / intérêt légitime	Aucun (interne à l'instance)	Durée de la relation, puis suppression du compte
Authentification à deux facteurs	Renforcer l'authentification	Utilisateurs ayant activé le 2FA	Graine TOTP, empreintes des codes de secours	Intérêt légitime (sécurité)	Aucun	Jusqu'à désactivation du 2FA
Stockage et partage de fichiers	Héberger et partager les fichiers déposés	Utilisateurs et destinataires de partages	Contenu des fichiers (susceptible de contenir des données personnelles), métadonnées, propriétaire	Selon la finalité définie par le responsable	Utilisateurs autorisés, destinataires des liens	Jusqu'à suppression par l'utilisateur ; corbeille purgée à 30 jours
Journalisation d'audit	Assurer la traçabilité et la sécurité	Utilisateurs	Identifiant, action, ressource, adresse IP, horodatage, détails	Obligation légale / intérêt légitime (sécurité)	Administrateurs habilités	Rotation à taille bornée (segment de 50 Mio, un segment conservé)

TRAITEMENT	FINALITÉ	CATÉGORIES DE PERSONNES	CATÉGORIES DE DONNÉES	BASE LÉGALE (INDICATIVE)	DESTINATAIRES	DURÉE DE CONSERVATION
Liens de partage public et demandes de dépôt	Permettre l'échange avec des tiers	Créateurs et utilisateurs des liens	Jeton, empreinte du mot de passe de protection, chemin de la ressource	Intérêt légitime	Détenteurs du lien	Expiration configurable ; purge à l'échéance
Limitation des tentatives (anti-force brute)	Protéger les comptes et les liens publics contre la recherche de mots de passe	Utilisateurs, personnes tentant de se connecter, utilisateurs des liens publics	Adresse IP, identifiant saisi, jeton du lien, nombre d'échecs et horodatages	Intérêt légitime (sécurité)	Aucun	En mémoire uniquement, jamais persistées ; effacées au redémarrage. Une entrée est conservée tant qu'elle peut armer ou maintenir un verrou (15 minutes après le dernier échec), puis supprimée par la purge périodique (toutes les 30 minutes)
Sessions d'envoi reprises	Fiabiliser les téléversements volumineux	Utilisateurs téléversant	Métadonnées de session (propriétaire, taille, avancement)	Intérêt légitime	Aucun	Durée de vie de session (purge des sessions inactives)

Transferts hors Union européenne. Aucun transfert n'est réalisé par le produit : l'ensemble des données demeure sur l'instance auto-hébergée par le responsable de traitement. La localisation effective des données dépend de l'hébergement choisi par ce dernier.

---

4. Protection des données dès la conception et par défaut (art. 25)

Les principes de l'article 5 (licéité, minimisation, exactitude, limitation de la conservation, intégrité et confidentialité) sont pris en charge par les mesures techniques suivantes.

PRINCIPE (ART. 5)	MESURE TECHNIQUE DANS LE PRODUIT
Minimisation des données	Champs personnels facultatifs (e-mail, nom) ; vues d'API expurgées ne renvoyant jamais d'empreinte ni de secret
Intégrité et confidentialité	Contrôle d'accès centralisé (RBAC) ; empreintes bcrypt ; secrets restreints en `0600` ; chiffrement de volume recommandé au niveau de l'hôte

PRINCIPE (ART. 5)	MESURE TECHNIQUE DANS LE PRODUIT
Limitation de la conservation	Purge de la corbeille à 30 jours ; rotation du journal d'audit ; expiration des liens de partage ; purge des sessions d'envoi inactives
Exactitude	Fonctions de rectification des comptes et des métadonnées
Licéité et transparence	Journalisation des accès ; documentation des traitements (présent registre)

Protection par défaut. Les cookies de session sont émis en `HttpOnly`, `SameSite=Strict` et `Secure` par défaut ; les en-têtes de proxy potentiellement usurpables ne sont pas exploités par défaut ; les contenus actifs déposés ne sont jamais servis comme tels. La révocation de l'ensemble des sessions d'un utilisateur est immédiate lors d'un changement de mot de passe, de rôle ou de droits, ainsi que lors de l'activation ou de la désactivation du double facteur. La suppression d'un fichier ou d'un dossier supprime également les liens publics et demandes de dépôt qui le visent.

---

5. Droits des personnes concernées et modalités d'exercice

DROIT (RGPD)	MODALITÉ D'EXERCICE DANS LE PRODUIT
Accès (art. 15)	Consultation du profil et des fichiers de l'utilisateur ; extraction du journal d'audit par un administrateur habilité
Rectification (art. 16)	Modification des métadonnées de compte et du contenu par l'utilisateur ou l'administrateur
Effacement (art. 17)	Suppression du compte et des fichiers ; purge définitive via la corbeille ; suppression des partages associés
Limitation (art. 18)	Désactivation d'un compte par l'administrateur
Portabilité (art. 20)	Téléchargement des fichiers (unitaire ou groupé) dans leur format d'origine
Opposition (art. 21)	Traitée organisationnellement par le responsable de traitement

Les demandes d'exercice des droits sont reçues et instruites par le responsable de traitement, l'éditeur n'ayant pas accès aux données de l'instance.

---

6. Évaluation du besoin d'analyse d'impact (art. 35)

Conformément à l'article 35 du RGPD et aux critères des lignes directrices du Comité européen de la protection des données (CEPD) et de la CNIL, une AIPD est requise lorsque le traitement est susceptible d'engendrer un risque élevé, notamment en cas d'évaluation systématique, de traitement à grande échelle de données sensibles ou de surveillance systématique.

Analyse. Le produit, dans sa conception, ne réalise ni profilage, ni décision automatisée, ni traitement de catégories particulières de données par nature. Les données personnelles traitées se limitent à des identifiants, des données de connexion et des traces d'audit ; le contenu des fichiers relève de l'usage défini par le responsable.

Conclusion. Une AIPD n'est **pas systématiquement requise** au seul titre du produit. Le responsable de traitement doit **la réévaluer selon son contexte de déploiement** — en particulier si l'instance est amenée à traiter des données sensibles, à grande échelle, ou concernant des personnes vulnérables. Dans ces cas, la conduite d'une AIPD, appuyée sur le modèle et le logiciel PIA de la CNIL, est recommandée.

---

7. Sécurité des traitements (art. 32)

Les mesures techniques et organisationnelles propres à garantir un niveau de sécurité adapté au risque sont détaillées dans le **Dossier de sécurité & modélisation des menaces** (document 06), qui couvre l'authentification, le contrôle d'accès, la protection des fichiers, la sécurité navigateur, la protection des données au repos, la journalisation et la résilience. Les résultats des campagnes de tests de sécurité y sont consignés.

---

8. Gestion des violations de données à caractère personnel

En cas de violation de données à caractère personnel (articles 33 et 34 du RGPD), le responsable de traitement met en œuvre la procédure suivante, dont les aspects techniques (isolement de l'instance, rotation des secrets, restauration) sont détaillés dans le **Dossier d'exploitation** (document 10, section relative aux runbooks) :

1. **Détection et qualification** — identification de l'incident à partir du journal d'audit et de la supervision.
2. **Confinement** — révocation des sessions (mécanisme de version de jeton), rotation du secret JWT, isolement de l'instance si nécessaire.
3. **Évaluation du risque** pour les droits et libertés des personnes concernées.
4. **Notification à l'autorité de contrôle** dans les 72 heures lorsque la violation présente un risque (art. 33).
5. **Communication aux personnes concernées** en cas de risque élevé (art. 34).
6. **Documentation** de la violation et des mesures correctives.

---

9. Références

- Règlement (UE) 2016/679 du 27 avril 2016 (RGPD), notamment les articles 5, 25, 30, 32, 33, 34 et 35.
- CNIL — *Guide de la sécurité des données personnelles*.
- CNIL — *Analyse d'impact relative à la protection des données (AIPD)* : la méthode, les modèles et le logiciel PIA.
- CEPD — *Lignes directrices concernant l'analyse d'impact relative à la protection des données (AIPD)*.